

MINI INCIDENT RESPONSE PLAN

MediCore Health — Patient Portal API Data Exposure

Author: Abdul Hadi Faheem

Vortex Tech Cyber Security Internship — Week 4 (Final Task)

Framework Reference: NIST SP 800-61 Incident Response Lifecycle

Table of Contents

Table of Contents.....	2
1. Scenario Overview	3
2. Incident Response Framework	3
3. Phase 1 — Preparation.....	3
4. Phase 2 — Detection & Analysis	4
How it was likely discovered.....	4
Initial investigation steps	4
5. Phase 3 — Containment	4
Short-term containment (within the first hour of confirmation)	4
Long-term containment	4
6. Phase 4 — Eradication.....	4
7. Phase 5 — Recovery.....	5
8. Phase 6 — Lessons Learned (Post-Incident Review).....	5
9. Internal Communication Plan	5
10. Preventative Measures	6
11. Conclusion.....	6

1. Scenario Overview

MediCore Health is a fictional mid-sized telehealth and patient-portal provider serving roughly 42,000 active patients across three states. In March 2026, a security researcher discovered that MediCore's patient-records API (/api/v2/patient-records) had been deployed to production without proper authentication enforcement on one of its query parameters. By manipulating a sequential patient_id value in the request, any unauthenticated user could retrieve full patient records — including names, dates of birth, diagnosis codes, insurance IDs, and prescription history.

Automated scraping activity against this endpoint had been occurring for approximately nine days before internal detection, exposing an estimated 42,000 patient records. This scenario mirrors real-world 2025-2026 healthcare breach patterns, where unsecured or misconfigured APIs and cloud-facing endpoints have become one of the fastest-growing initial access vectors in the sector.

2. Incident Response Framework

This plan follows the NIST Incident Response Lifecycle, which defines six phases:

- Preparation
- Detection & Analysis
- Containment
- Eradication
- Recovery
- Post-Incident Activity (Lessons Learned)

3. Phase 1 — Preparation

Before this incident, MediCore Health should have had the following in place:

- Incident Response Team (IRT): A designated cross-functional team including a security lead, IT/DevOps engineer, legal/compliance officer, and a communications lead, with an on-call rotation and a documented escalation path.
- Monitoring & Alerting: A Web Application Firewall (WAF) and API gateway with logging enabled, feeding into a centralized SIEM (e.g., Wazuh, Splunk) capable of flagging abnormal query volume per client.
- Backups: Encrypted, regularly tested backups of the patient database and application configuration, stored separately from production credentials.
- Access Control Baseline: Documented API authentication standards (OAuth2/JWT enforcement) required before any endpoint reaches production, verified through a pre-deployment security review checklist.
- Incident Response Runbook: A pre-written playbook specific to "data exposure via API" scenarios, so the team isn't improvising under pressure.
- Regulatory Readiness: A pre-drafted breach notification template aligned with HIPAA's Breach Notification Rule, reviewed by legal in advance.

4. Phase 2 — Detection & Analysis

How it was likely discovered

A third-party security researcher, while testing the public-facing portal, noticed that sequential patient IDs returned full records without a valid session token. They responsibly disclosed this to MediCore's published security contact. Independently, MediCore's WAF logs later confirmed a pattern of abnormally high, sequential GET requests to `/api/v2/patient-records` originating from a small set of IP ranges over the prior nine days — a pattern that should have triggered an automated anomaly alert but did not, due to an under-tuned alerting threshold.

Initial investigation steps

- Validate the researcher's report by attempting to reproduce the issue in a staging environment.
- Pull WAF and API gateway logs for the affected endpoint covering the suspected exposure window.
- Identify the volume, date range, and IP sources of anomalous requests.
- Determine the scope of data actually accessible via the endpoint (which fields, which patient ID range).
- Classify the incident severity (in this case: high — confirmed unauthorized access to PHI at scale).
- Notify the Incident Response Team lead to formally open an incident ticket and begin the response timeline log.

5. Phase 3 — Containment

Short-term containment (within the first hour of confirmation)

- Immediately disable or restrict the `/api/v2/patient-records` endpoint at the API gateway/load balancer level.
- Revoke and rotate any API keys or service credentials associated with that endpoint.
- Block the identified source IP ranges at the WAF while investigation continues.
- Enable verbose logging on adjacent endpoints in case the exposure extends further than initially scoped.

Long-term containment

- Stand up a temporary maintenance page or degraded-mode version of the patient portal that does not expose the vulnerable API path.
- Isolate the affected application server/container from other production services to prevent lateral movement, in case this was part of a broader compromise rather than an isolated misconfiguration.
- Preserve forensic evidence (logs, request payloads, server state) before any remediation changes are made, to support the later investigation and any regulatory reporting.

6. Phase 4 — Eradication

- Patch the root cause: enforce authentication and session-token validation on the `/api/v2/patient-records` endpoint, and audit all other API endpoints for the same missing-auth pattern.
- Remove any unauthorized access — rotate all credentials and secrets that could plausibly have been harvested during the exposure window, even if not directly confirmed as accessed.

- Conduct a full code review of the API layer to confirm no other endpoints share the same authentication gap (this class of bug rarely occurs in isolation).
- Scan for any webshells, persistence mechanisms, or unauthorized accounts, in case the scraping activity was paired with a deeper compromise attempt.
- Confirm with the security researcher and internal logs that the vulnerable code path has been fully closed, not just filtered at the WAF.

7. Phase 5 — Recovery

- Redeploy the patched API behind proper authentication, first to staging for validation, then to production during a low-traffic maintenance window.
- Restore full portal functionality gradually, monitoring API gateway and SIEM dashboards closely for any recurrence of the anomalous request pattern.
- Increase logging retention and alert sensitivity on this endpoint class for a defined heightened-monitoring period (e.g., 30 days) post-incident.
- Validate database integrity — confirm no records were altered or deleted, only read/exfiltrated.
- Formally close the incident ticket once monitoring confirms stability, with a documented timeline of all actions taken.

8. Phase 6 — Lessons Learned (Post-Incident Review)

A post-incident review, held within one to two weeks of resolution, would likely conclude:

- Root cause: A missing authentication check was not caught because the pre-deployment security review checklist was not consistently enforced for API changes shipped outside the normal release cycle.
- Detection gap: The WAF/SIEM anomaly threshold for this endpoint class was tuned too loosely, delaying detection by several days beyond what automated alerting should have caught.
- Process change: API authentication checks should be a mandatory, automated gate in the CI/CD pipeline (e.g., a test that fails the build if a new endpoint lacks an auth decorator), rather than relying solely on manual review.
- Detection improvement: Anomaly alert thresholds for PHI-handling endpoints should be re-tuned and independently audited on a recurring schedule.
- Documentation update: The incident response runbook should be updated with the specific timeline and decisions from this incident, to speed up response to any similar future event.

9. Internal Communication Plan

Timeframe	Who is Notified	Purpose
Immediately (within 30 min)	Security Lead, CTO, CEO	Confirm severity, authorize containment

Within 2-4 hours	Legal/Compliance, Data Protection Officer	Begin regulatory impact assessment (HIPAA)
Within 24 hours	Engineering staff (need-to-know)	Coordinate patching, credential rotation, monitoring
Per HIPAA timeline (no unreasonable delay, max 60 days)	Affected patients, HHS OCR / regulators	Formal breach notification, per legal counsel
Ongoing	Internal all-hands	Transparency on remediation status

Note: exact legal notification deadlines and thresholds should always be confirmed with legal counsel; this plan describes the process conceptually rather than citing binding legal text.

10. Preventative Measures

- Mandatory automated authentication testing in CI/CD — no API endpoint should be able to reach production without an automated test confirming it rejects unauthenticated requests. This directly addresses the root cause of this incident.
- Regular API security audits and penetration testing — a quarterly review of all public-facing API endpoints, specifically checking for authentication and authorization gaps, would likely have caught this before external discovery.
- Tighter anomaly detection thresholds for PHI-handling endpoints — request-volume and pattern-based alerting tuned specifically for sensitive data endpoints, reviewed and re-calibrated on a recurring basis rather than set once and forgotten.

11. Conclusion

This incident illustrates a pattern seen repeatedly across the healthcare sector in 2025-2026: a single missing authentication check on a data-facing API can expose tens of thousands of patient records without requiring any sophisticated attack technique. Structured, phase-based incident response — paired with proactive preventative controls — is what separates a contained, well-managed incident from a prolonged, costly breach.